

Enhanced Tabletop Exercise

Business Email Compromise and Wire Fraud

Executive impersonation, lookalike-domain phishing, payment-control bypass, and fraudulent wire transfer response

Field	Details
Scenario type	Business Email Compromise (BEC) / Payment Fraud / Email Impersonation
Primary audience	Executive, treasury, fraud, legal, compliance, communications, crisis management, and technical response teams
Exercise duration	60-90 minutes
Format	Facilitated tabletop exercise with phased injects, evidence cards, decision points, and debrief
Classification	Internal use only - fictional exercise material
Version	Enhanced technical-depth version - generated 13 July 2026

Facilitator note

This document is designed for live facilitation. All indicators, domains, email addresses, IP addresses, account names, payment references, and beneficiary details are fictional and intended for exercise use only.

Document Map

This enhanced tabletop exercise preserves the original structure while strengthening the technical attack path, scenario evidence, and end-of-document MITRE ATT&CK mapping. It is ready for direct use by a facilitator, with optional branches that can be activated depending on participant maturity and time available.

- Exercise overview, purpose, scope, assumptions, and rules of engagement
- Scenario summary and threat context with explicit attack-path options
- Phased injects with participant knowledge, technical artifacts, discussion questions, expected actions, and facilitator notes
- Decision points, business impacts, facilitator guide, evaluation criteria, and debrief
- Recommended improvement actions, optional variants, and final MITRE ATT&CK mapping

Integrated improvements from evaluation feedback

The revised exercise explicitly distinguishes spoofed email, lookalike-domain impersonation, and account-takeover hypotheses; adds sample email authentication artifacts, indicators, identity logs, and payment records; expands scoping actions for Security and Fraud; and maps the scenario across reconnaissance, resource development, social engineering, initial access, credential access, defense evasion, discovery, collection, exfiltration, and impact where applicable.

1. Exercise Overview

Field	Exercise Design
Title	Executive Impersonation and Fraudulent Wire Transfer
Scenario type	Business Email Compromise (BEC) / Payment Fraud / Credential-Phishing Support Infrastructure
Audience	Executive, operational, treasury, fraud, legal, compliance, communications, and technical response stakeholders
Duration	60-90 minutes
Format	Facilitated tabletop exercise with phased injects, optional technical evidence cards, and a final debrief
Classification	Internal use only
Exercise style	Discussion-based; no production systems are accessed or modified
Primary decision pressure	Urgent payment approval, partial information, executive pressure, recovery window, and regulatory / reputational uncertainty

2. Purpose

This tabletop exercise is designed to test the organization's ability to identify, contain, escalate, investigate, and recover from a business email compromise attempt involving executive impersonation and an urgent overseas wire transfer request. The exercise focuses on fraud controls, crisis decision-making, email and identity security triage, payment recall, evidence preservation, legal and regulatory coordination, and executive communications.

The scenario intentionally sits at the boundary between business-process fraud and cybersecurity. Participants must determine when a suspicious payment request becomes a fraud event, a cyber incident, or a combined incident requiring a coordinated command structure.

3. Exercise Objectives

By the end of the exercise, participants should be able to:

- 1 Validate controls for urgent, high-value, cross-border, and newly introduced beneficiary payment requests.
- 2 Assess whether out-of-band verification and dual authorization procedures are understood, mandatory, logged, and consistently applied.
- 3 Test escalation paths between Treasury, Finance, Fraud, Security, Legal, Compliance, Communications, Crisis Management, and Executive leadership.
- 4 Evaluate the organization's ability to respond once a fraudulent transfer has been released and the recovery window is narrowing.
- 5 Review evidence preservation, recall coordination, correspondent-bank engagement, law-enforcement considerations, and regulatory-assessment triggers.
- 6 Distinguish among display-name abuse, lookalike-domain impersonation, direct domain spoofing, and potential valid-account compromise.
- 7 Practice technical scoping actions: email-header analysis, message trace, domain intelligence review, URL detonation, identity log review, mailbox-rule review, and environment-wide searches for similar lures.
- 8 Identify gaps in payment playbooks, fraud / cyber handoffs, executive communications, user awareness, and technical detection controls.

Audience-specific objectives

Audience	Objectives
Executive / crisis leadership	Clarify decision authorities, risk appetite, escalation thresholds, board / regulator briefing expectations, and internal / external message discipline.
Treasury / payment operations	Validate payment-control triggers, exception governance, callback evidence, beneficiary verification, recall workflow, and queue prioritization.
Fraud / investigations	Coordinate bank-to-bank recovery, beneficiary intelligence, case documentation, law-enforcement liaison, and suspected mule-account handling.
Security / technical response	Analyze email authenticity, identity exposure, malicious infrastructure, similar-message spread, and mailbox / endpoint compromise indicators.
Legal / compliance / privacy	Assess notification obligations, privilege, evidence handling, customer impact, regulatory touchpoints, and insurer / law-enforcement engagement.
Communications	Prepare fact-based holding statements, stakeholder updates, executive talking points, and response to media or client inquiries.

4. Suggested Participants

Executive / strategic participants	Operational participants	Technical / control participants
CFO or delegate COO / business leadership representative Crisis management lead Corporate communications lead Legal counsel Compliance / regulatory affairs lead Privacy / data protection lead	Treasury operations manager Payment operations lead Fraud investigations lead Relationship / correspondent banking representative Business continuity lead Client relationship lead Internal audit or operational risk observer	Security operations / incident response lead Email security / messaging administrator Identity and access management representative Threat intelligence analyst Insider risk / monitoring representative Records / forensic preservation representative Security communications liaison

Suggested role discipline

- Participants should answer from their real role, current authority, and actual process rather than an idealized process.
- The facilitator should ask who has authority to decide, who must be informed, who executes, and where the decision is documented.
- Observers should capture gaps, dependencies, and improvement actions without interrupting the exercise flow.

5. Scope

In scope	Out of scope
Executive impersonation by email Payment approval workflow and exception handling Fraud detection and wire recall process Internal escalation and crisis coordination External notifications to correspondent / beneficiary institutions Preservation of email, logs, approval evidence, and communications Executive, legal, regulatory, and client-impact decision-making Email authentication, message trace, lookalike-domain, URL, identity, and mailbox-rule triage Temporary enhanced controls for urgent wires, new beneficiaries, and executive requests	Malware reverse engineering beyond basic URL / attachment triage Full endpoint forensic imaging unless activated as a variant Production payment-system testing Live outreach to external banks, clients, regulators, law enforcement, or vendors Attribution to a named real-world threat actor Use of real customer data, real payment instructions, or real infrastructure

6. Assumptions

- The organization is a commercial bank with established treasury and high-value payment approval processes.

- High-value and urgent transfer requests require dual authorization and may require enhanced verbal or authenticated verification.
- Email is widely used for internal executive-to-operations communication, but payment instructions are not considered sufficiently verified on email alone.
- A standard fraud recall or financial-institution recovery process exists, but its timing, ownership, and escalation paths may be unclear under pressure.
- Security has access to email gateway logs, message trace, identity provider logs, mailbox audit logs, and endpoint / EDR visibility within normal retention limits.
- The scenario is fictional and discussion-based. Participants should respond according to existing roles, authorities, escalation channels, and procedures.
- All technical indicators are fictional and use reserved or example identifiers. They should not be blocked or searched in production systems.
- Legal, regulatory, privacy, insurer, and law-enforcement obligations depend on jurisdiction, impact, recovery status, and facts known at the time. Participants should identify who makes those assessments rather than assume a single universal threshold.

7. Rules of Engagement

- This is a no-fault learning exercise.
- Real-world incidents take precedence over the exercise.
- Participants should not fight the scenario; work with the facts provided by the facilitator.
- There are no perfect answers; the goal is to identify strengths, gaps, dependencies, and decision points.
- Facilitators may introduce new facts as the scenario evolves or activate optional variants.
- No live production actions should be taken. Do not contact real external parties based on exercise injects.
- All exercise notes should be handled according to the stated classification and retained according to internal practice.

8. Scenario Summary

A financially motivated threat actor conducts a targeted business email compromise campaign against the bank's payment approval process. The actor researches senior finance leaders, treasury operating cadence, recent corporate activity, and likely payment approvers. The actor then registers a lookalike domain and builds a simple credential-harvesting page that mimics the organization's cloud login page and deal-room portal.

A senior manager in treasury operations receives an email that appears to come from the CFO. The message references a confidential acquisition closing and instructs the recipient to release a large overseas wire transfer to a new beneficiary. The email uses executive authority, secrecy, and deadline pressure. It includes a link to a supposedly secure closing package and asks that normal communication channels not be used because the deal is market-sensitive.

Under pressure, the payment enters an exception path. Shortly after release, the CFO denies sending the request. The organization must rapidly determine whether the event is a payment fraud case, a cyber incident, or both. The team must preserve evidence, initiate wire recall, scope the email and identity exposure, brief leadership, and decide whether temporary payment restrictions, regulatory notifications, law-enforcement contacts, insurer notices, or client communications are required.

9. Threat Context

Threat actor profile

- Motivation: direct financial theft through fraudulent wire transfer.

- Tradecraft: business email compromise, executive impersonation, lookalike-domain infrastructure, urgency / confidentiality pressure, and optional credential harvesting.
- Likely preparation: public-source research on executives and finance staff, domain registration, email account setup, and beneficiary / mule-account coordination.
- Primary objective: cause the bank to release funds before verification controls, fraud analytics, or correspondent-bank controls can intervene.

Defined attack paths

Path	Description	Status in base scenario	Key controls to test
A. Lookalike-domain impersonation	The email uses a domain visually similar to the legitimate bank domain. SPF / DKIM / DMARC may pass for the lookalike domain, but the sender is not the real CFO mailbox.	Confirmed base path	Domain-similarity detection, display-name impersonation controls, user reporting, message trace, and out-of-band verification.
B. Direct spoofing of legitimate domain	The email claims to be from the legitimate bank domain but fails SPF, DKIM, or DMARC alignment.	Hypothesis to rule out	DMARC enforcement, gateway controls, quarantine handling, header analysis, and user-visible warning banners.
C. Valid-account compromise	A real executive, assistant, or finance mailbox is compromised and used to send or hide messages.	Optional variant / not confirmed initially	Identity logs, MFA events, session revocation, mailbox rules, forwarding, OAuth grants, and conditional access review.
D. Credential-phishing support	The email includes a link to a fake closing package or cloud login page designed to capture credentials or session material.	Attempted in base scenario	URL detonation, proxy logs, browser isolation, MFA, identity alerts, and user reporting.

Attack lifecycle narrative

Stage	Exercise detail	Defender visibility
Reconnaissance	Actor identifies CFO, treasury managers, deal cadence, approval language, and external counsel references from public sources and previous benign emails.	Mostly external; detect indirectly through brand / domain monitoring and suspicious social-media contact patterns.
Resource development	Actor registers example-bankcorp.example, configures mail service, and hosts a fake closing package at secure-closing.example.	Domain-monitoring alerts, certificate transparency, passive DNS, newly observed sender domain, and mail gateway enrichment.
Delivery / social engineering	Email impersonates the CFO and references Project Cedar, an urgent acquisition closing. The link is presented as supporting documentation.	Email gateway, user report, message trace, URL click telemetry, and mail authentication results.
Business process abuse	The actor pushes secrecy, time pressure, and executive authority to bypass callback and beneficiary-verification controls.	Payment workflow audit trail, exception approvals, chat / call records, and treasury control logs.
Recovery and response	Once fraud is suspected, the bank initiates wire recall, scopes similar lures, preserves evidence, and briefs leadership.	Fraud case system, incident records, payment-system logs, legal hold, and executive briefing materials.

Fictional indicators and artifacts

Artifact type	Value	Use in exercise
Lookalike sender domain	example-bankcorp.example	Domain resembles legitimate bank branding but is not owned by the bank.
Reply-to domain	secure-closing.example	Used to redirect responses away from the visible From address.
URL	hxxps://secure-closing.example/doc/cedar	Fake closing package / credential prompt. Do not browse in production.
Mail source IP	198.51.100.24	Reserved exercise IP shown in email headers and gateway logs.
Secondary IP	203.0.113.45	Reserved exercise IP shown in identity logs for attempted login.
Subject line	Project Cedar: settlement instruction - closing window	High-pressure business lure.
Beneficiary	North Bridge Advisory Pte Ltd	New overseas beneficiary not present in normal payment history.
Payment amount	USD 8,750,000	Large cross-border wire requiring enhanced controls.
Scenario discipline Facilitators should keep the base case clear: the confirmed attack path is lookalike-domain impersonation supported by a phishing link. Account takeover is an optional branch, not an assumed fact, unless the facilitator deliberately activates it.		

10. Exercise Timeline and Injects

Phase	Time	Focus	Core decision pressure
1	09:15	Suspicious executive request	Pause payment vs. comply with urgent executive instruction.
2	10:05-11:00	Exception path and released wire	Recall funds and activate coordinated command before complete certainty.
3	13:30	Containment and wider exposure	Determine whether this is a single fraud case or a broader cyber campaign.
4	Next business day	Recovery, reporting, and remediation	Brief leadership and decide legal / regulatory / client / control response.

Phase 1 - Suspicious Executive Request

Inject 1

A senior manager in Treasury Operations receives an email appearing to come from the CFO. The message states that a confidential acquisition closing is occurring today and instructs the manager to immediately release a high-value overseas wire transfer to a newly provided beneficiary. The message emphasizes that timing is critical, that the matter is highly confidential, and that ordinary communication channels may delay or jeopardize the closing.

The email includes a link to a purported closing package and requests confirmation only by reply to the email thread. The CFO is believed to be in an off-site meeting and is not immediately reachable through chat.

What participants know at this stage

- The email appears legitimate at first glance and uses the CFO display name.
- The sender address is visually similar to the organization's domain but not identical.
- The transfer is large, cross-border, time-sensitive, and addressed to a newly introduced beneficiary.

- The request discourages ordinary verification and frames the matter as highly confidential.
- The email contains a link to a purported closing package.
- No payment has been released yet.

Technical artifact card - Email excerpt

```
From: "Jane Morris, CFO" <jane.morris@example-bankcorp.example>  
To: Treasury Operations Manager <treasury.manager@bank.example>  
Reply-To: Deal Closing Desk <dealdesk@secure-closing.example>  
Subject: Project Cedar: settlement instruction - closing window  
Date: Tue, 14 Oct 2026 09:15:42 -0400
```

We are at the final signing window for Project Cedar. Please release USD 8,750,000 to North Bridge Advisory Pte Ltd using the attached settlement details.

Do not route this through the normal group mailbox. Legal is limiting distribution until signatures are complete. I need confirmation within 30 minutes.

Closing package: [hxxps://secure-closing.example/doc/cedar](https://secure-closing.example/doc/cedar)

Technical artifact card - Authentication results

```
Authentication-Results: mx.bank.example;  
spf=pass smtp.mailfrom=bounce@example-bankcorp.example;  
dkim=pass header.d=example-bankcorp.example;  
dmarc=pass header.from=example-bankcorp.example;  
compauth=fail reason=domain_impersonation;  
x-impersonation-risk=high;  
x-newly-observed-domain=true;  
Received: from mail.example-bankcorp.example (198.51.100.24)  
Message-ID: <20261014091542.66421@mail.example-bankcorp.example>
```

Discussion questions

- 1 What immediate actions should the recipient take before any approval occurs?
- 2 Which payment controls should be triggered by the size, urgency, geography, beneficiary change, and confidentiality language?
- 3 Is the request sufficient to justify pausing payment execution? Who has authority to pause?
- 4 What out-of-band verification methods are mandatory, and what sources of contact information are acceptable?
- 5 Who should be informed internally at this stage: Treasury leadership, Fraud, Security, Legal, or the CFO's office?
- 6 What evidence should be preserved immediately, and by whom?
- 7 What technical indicators should Security validate without delaying the payment-control decision?

Expected actions

- Halt or place the payment in review pending verification.
- Validate the request using established out-of-band procedures, using known-good phone numbers or authenticated executive channels.
- Verify beneficiary history, payment amount, settlement context, and approval authority.
- Report the message to Security or the phishing mailbox without forwarding in a way that strips headers.
- Inspect sender domain, reply-to, message routing, URL, display-name impersonation warnings, and authentication results.
- Escalate to Treasury leadership, Fraud, and Security if indicators remain suspicious.
- Preserve the email, full headers, message trace, URL, approval records, and any chats or calls.

Facilitator notes

Prompt participants to discuss practical friction points: executive pressure, after-hours approvals, confidential deals, unavailable approvers, insecure callback practices, and whether exception handling is too permissive. If the group approves the payment without out-of-band verification, move quickly to Phase 2. If the group blocks the payment, use Phase 2 as a hypothetical near miss and test recovery actions anyway.

Phase 2 - Pressure, Exception Path, and Transfer Release

Inject 2

The payment is released after a pressured approval path. A participant learns shortly afterward that the CFO denies sending the email. The organization must now decide how to initiate a fraud recall, preserve evidence, notify counterpart institutions, and brief executives. Time is critical because the transfer may soon move through additional accounts.

Payment operations confirms that the USD 8,750,000 wire was released through a correspondent route. The beneficiary bank has not confirmed receipt or hold status. A treasury analyst reports that they clicked the closing-package link but closed the browser when it requested credentials.

What participants know at this stage

- The wire has been released.
- The CFO states the message is fraudulent and did not originate from the CFO's mailbox.
- The beneficiary account is outside the bank's normal payment pattern.
- At least one user clicked the link, but no credential submission is confirmed.
- The recovery window is narrowing, and certainty is incomplete.
- Internal concern rises that this is a BEC-driven wire fraud event with cyber indicators.

Technical / payment artifact card

```
Payment reference: WIRE-2026-10-14-884201
Amount: USD 8,750,000
Originating account: Corporate treasury operating account
Beneficiary: North Bridge Advisory Pte Ltd
Beneficiary bank country: Singapore
Intermediary route: Correspondent Bank A -> Beneficiary Bank B
Entered by: Treasury Operations Manager
Approval path: CFO email request + two internal approvals; callback exception noted
Exception reason: Confidential M&A closing; executive unavailable
Time released: 10:05:18 -0400
```

Discussion questions

- 1 Who owns incident command now: Treasury, Fraud, Security, Crisis Management, or a joint structure?
- 2 What are the first 15-30 minute actions to maximize the chance of fund recovery?
- 3 Which external institutions must be contacted, by whom, using which trusted channels, and in what order?
- 4 When should Legal and Compliance be engaged?
- 5 What facts are required before briefing executives, and what can be briefed as assumptions?
- 6 What evidence must be preserved to support investigation, recovery, insurance, legal privilege, and regulatory assessment?
- 7 What thresholds trigger crisis governance activation?
- 8 How will the bank manage internal communications while facts are still developing?

Expected actions

- Initiate fraud recall or financial-institution recovery procedures immediately.
- Contact beneficiary bank and correspondent / intermediary institutions through trusted fraud channels.
- Open a combined fraud / cyber incident record and establish a clear command structure with a single action log.
- Notify executive leadership with facts, assumptions, decisions needed, and next update cadence.
- Preserve payment records, email records, full headers, message trace, URL logs, identity logs, approval evidence, callback records, and chat / call records.

- Block or quarantine the lookalike domain, URL, and related sender indicators; search for similar messages across the environment.
- Evaluate the clicked-link exposure: proxy logs, browser telemetry, identity-provider sign-in logs, MFA prompts, and session tokens.
- Temporarily increase scrutiny for urgent wires, new beneficiaries, large cross-border payments, and executive requests.

Facilitator notes

Push participants on speed versus certainty. Recovery decisions often must be made before complete forensic confirmation. Explore whether the institution has a single coordinated fraud / cyber playbook or fragmented procedures. Ask who can approve contacting external institutions, law enforcement, insurer hotlines, or regulators after hours.

Phase 3 - Containment, Investigation, and Wider Exposure Assessment

Inject 3

Initial review indicates the CFO's legitimate mailbox was not used. The email came from a lookalike domain registered seven days earlier. The fake closing-package URL displayed a cloud-login prompt. Identity logs show one denied MFA prompt from an unfamiliar network after the treasury analyst clicked the link. Security finds similar lure language sent to 12 finance and treasury users. Investigators cannot yet rule out compromise of an executive support mailbox, but there is no confirmed endpoint compromise.

What participants know at this stage

- The confirmed base path is lookalike-domain impersonation, not direct CFO mailbox compromise.
- A credential-harvesting link was included, and at least one user interacted with it.
- No successful suspicious login is confirmed, but identity telemetry requires review.
- Similar messages may have reached other finance approvers.
- Media, clients, and regulators are not yet aware.
- Business teams want to resume urgent payment processing, but risk of follow-on attempts remains.

Technical artifact card - Identity and message-trace snippets

```
Message trace:
Sender domain: example-bankcorp.example
First seen: 2026-10-14 09:12 -0400
Recipients: 12 internal users in Treasury, Finance, Executive Support
URL rewritten: true
Initial verdict: delivered to junk for 8 users; inbox for 4 users
User reports received: 2
```

```
Identity log:
User: treasury.analyst@bank.example
Event: MFA challenge after web login attempt
Source IP: 203.0.113.45
Geo: unexpected for user
Result: MFA denied by user; no successful session established
Follow-up: revoke sessions and reset credentials pending confirmation
```

Discussion questions

- 1 What scoping actions should Security take now?
- 2 Do you search for similar messages across the environment, and who approves tenant-wide search and purge?
- 3 What indicators are blocked, monitored, or shared internally?
- 4 Should enhanced monitoring or temporary payment restrictions be applied? For how long and by whose authority?
- 5 What is the threshold for treating this as an enterprise campaign rather than a single fraud case?

- 6 What identity actions are proportionate when a user clicked but no credential submission or successful login is confirmed?
- 7 Who decides whether clients, partners, auditors, insurers, regulators, or law enforcement are notified?
- 8 How does the group avoid both under-scoping the cyber component and over-claiming facts not yet proven?

Expected actions

- Search the environment for similar emails, domains, reply-to addresses, URLs, subjects, and lure text.
- Review executive, assistant, and finance mailbox activity, forwarding rules, OAuth grants, inbox rules, and unusual sign-ins as applicable.
- Review click logs, proxy logs, browser telemetry, identity-provider logs, MFA events, conditional-access results, and session activity.
- Block domains / URLs, remove messages from mailboxes if policy permits, and issue targeted awareness to likely recipients.
- Reset credentials or revoke sessions for exposed users if risk warrants; document the basis for the action.
- Coordinate communications and legal review before external statements or notifications.
- Document decisions, timelines, authorities, evidence handling, and unresolved assumptions.
- Maintain temporary enhanced payment controls until Security and Fraud agree the active wave is contained.

Facilitator notes

Use this phase to test cross-functional coordination between cyber, fraud, treasury, legal, and communications. If participants focus only on the single wire, prompt them to consider systemic exposure. If participants assume full compromise without evidence, ask what telemetry supports that conclusion and what business impact unnecessary restrictions could create.

Phase 4 - Outcome, Recovery, and Reporting

Inject 4

The bank receives partial feedback from external institutions. The beneficiary bank placed a hold after receiving the recall request, but a portion of the funds may already have moved onward. Leadership requests a decision on communications, legal and regulatory assessment, customer impact, insurer / law-enforcement engagement, and immediate control remediation.

Facilitator choice - recovery outcome

Option	Recovery result	Learning emphasis
A	Full freeze before onward movement	Near-miss controls, documentation, and sustainable remediation.
B	Partial recovery: USD 7.1M frozen; USD 1.65M moved onward	Financial exposure, recovery coordination, insurer / legal strategy, and executive briefing under uncertainty.
C	No recovery; funds moved through additional accounts	Loss acceptance, regulatory / board escalation, reputational response, and root-cause accountability.

What participants know at this stage

- Recovery outcome is uncertain or partial.
- Control weaknesses and exception handling gaps are visible.
- A phishing link and lookalike domain were used, but there is no confirmed internal mailbox compromise in the base scenario.
- Executive leadership wants a clear impact statement and next-step plan.
- Legal, Compliance, Privacy, law-enforcement, insurer, and regulatory considerations may apply depending on facts and jurisdiction.

Discussion questions

- 1 How is business impact assessed and communicated to leadership?
- 2 What legal, regulatory, insurer, and law-enforcement considerations apply, and who owns each assessment?
- 3 How is reputational risk managed if the event becomes public?
- 4 What immediate control changes should be made before business-as-usual resumes?
- 5 What should be included in the post-incident report and lessons-learned review?
- 6 What evidence and decision logs must be retained?
- 7 Who signs off on return to normal payment processing?

Expected actions

- Confirm financial exposure, recovery status, residual risk, and next recovery steps.
- Prepare an executive briefing with facts, assumptions, decisions made, open questions, risk rating, and next actions.
- Determine reporting obligations with Legal, Compliance, Privacy, and relevant business owners.
- Coordinate with law enforcement and insurer contacts as appropriate.
- Implement short-term controls for payment approvals, beneficiary changes, executive requests, and high-risk wire corridors.
- Complete technical containment and monitoring, including indicators, message purge, affected-user review, and domain monitoring.
- Launch a post-incident review with clear owners, due dates, and governance tracking.

- Capture lessons learned across fraud, cyber, treasury, crisis management, communications, and executive decision-making.

Facilitator notes

Allow the group to discuss multiple possible endings: successful recall, partial loss, full loss, or discovery of wider targeting. This helps test resilience across different outcomes. Keep the legal / regulatory discussion fact-based and jurisdiction-aware; the expected answer is who assesses and how evidence is gathered, not a single universal reporting rule.

11. Decision Points

Decision point	Primary owner	Evidence / inputs needed	Potential failure mode
Pause or release payment	Treasury / payment authority	Payment value, beneficiary history, callback evidence, approvals, suspicious indicators	Urgency and executive pressure override mandatory controls.
Classify as fraud, cyber, or combined incident	Fraud + Security + Crisis lead	CFO denial, email artifacts, payment status, clicked-link telemetry, identity logs	Siloed fraud and cyber workstreams delay response.
Initiate recall before full validation	Fraud / payment operations	Payment reference, beneficiary bank, correspondent route, amount, release time	Waiting for perfect certainty loses recovery window.
Activate crisis governance	Crisis management lead / executive sponsor	Potential loss, control breakdown, client / regulator / media exposure, operational impact	No single commander or action log.
Apply temporary payment restrictions	Treasury leadership / COO	Risk of similar lures, business criticality, payment backlog, control capacity	Restrictions are too weak to contain risk or too broad to sustain operations.
Perform tenant-wide search and purge	Security lead / messaging admin	Indicators, legal / privacy approval if required, mail platform capability	Incomplete search leaves lures active in mailboxes.
Take identity containment actions	IAM / Security	Click data, login attempts, MFA events, session tokens, device posture	Overly slow action allows account takeover; overly broad action disrupts operations.
Notify external parties	Legal / Compliance / Fraud / Communications	Impact facts, jurisdiction, recovery status, contractual duties, insurer terms	Premature or delayed notifications create legal and reputational risk.
Resume normal payment processing	Treasury + Fraud + Security	Containment status, active indicators, enhanced controls, backlog, executive signoff	Business-as-usual resumes before active campaign is contained.

12. Operational and Business Impacts

Impact category	Potential impact
Operational	Disruption to high-value payment approvals; increased manual review of urgent transfers; payment backlog; additional validation burden for Treasury, Fraud, and Operations; emergency coordination across time zones.
Financial	Direct financial loss; partial or delayed recovery; correspondent-bank fees; insurance deductible / coverage questions; liquidity or settlement impacts depending on account and timing.
Cyber / technical	Increased Security workload; message search and purge; identity reviews; temporary controls; logging and evidence-retention demands; need to distinguish attempted from successful compromise.
Legal / regulatory	Regulatory notification assessment; law-enforcement engagement; legal privilege and evidence preservation; insurer notification; contractual obligations to clients or partners depending on impact.
Reputational	Reduced confidence in executive communications and payment controls; possible media, client, auditor, board, or regulator scrutiny.
People / governance	Role confusion between fraud and cyber teams; decision fatigue; executive pressure; need for clear command structure and action tracking.

13. Facilitator Guide

Suggested flow

Time	Activity
0-10 min	Introduction, objectives, scope, assumptions, and rules of engagement.
10-25 min	Phase 1 discussion: suspicious request and pre-payment control decision.
25-45 min	Phase 2 discussion: released wire, recall, evidence preservation, and command structure.
45-65 min	Phase 3 discussion: technical scoping, wider exposure, and temporary controls.
65-80 min	Phase 4 discussion: recovery outcome, reporting, and remediation.
80-90 min	Debrief, evaluation scoring, and improvement-action capture.

Facilitation tips

- Ask participants to identify the decision owner, executor, approver, informed parties, and documentation location for each major action.
- Separate facts from assumptions. Ask what evidence would confirm or disprove a mailbox compromise, credential compromise, or broader campaign.
- Challenge informal workarounds: personal mobile numbers, executive pressure, email-only approvals, and undocumented exception paths.
- Track where controls exist on paper but are bypassed in practice.
- Use time pressure deliberately. Recovery actions should not wait for complete forensic certainty.
- Invite both business and technical participants to explain tradeoffs in plain language.
- Use optional variants only when they support learning objectives and do not distract from core BEC response.

Evidence prompts

Ask participants whether they would know how to quickly access and preserve:

- Full email headers and message trace data
- Mail gateway verdicts, URL rewriting, click telemetry, and quarantine / purge records

- Payment-system audit logs, approval records, callback evidence, and beneficiary-maintenance history
- Identity-provider sign-in logs, MFA events, session tokens, conditional-access decisions, and mailbox audit logs
- Mailbox rules, forwarding settings, delegated access, OAuth grants, and executive support mailbox activity
- Call recordings, voice-verification records, chats, meeting notes, and incident action logs
- Correspondent-bank contact records, recall timestamps, and recovery status updates

Facilitator prompts to deepen technical discussion

- What exact header field or security-control output tells you this is a lookalike domain rather than the real CFO mailbox?
- If SPF / DKIM / DMARC pass for the lookalike domain, what controls detect brand or display-name impersonation?
- How do you determine whether the phishing link captured credentials or session tokens?
- What would you search in message trace: sender IP, domain, reply-to, URL, subject, body text, or recipient list?
- What identity events would justify password reset, session revocation, device isolation, or broader account review?
- What are you comfortable telling executives before scoping is complete?

14. Evaluation Criteria

Area	Strong performance indicators
Recognition of BEC indicators	Participants identify urgency, confidentiality pressure, new beneficiary, lookalike domain, reply-to mismatch, and abnormal payment pattern.
Payment-control adherence	Payment is paused or challenged; callback and dual authorization are applied using trusted channels; exceptions are documented and escalated.
Timeliness of escalation	Treasury, Fraud, Security, Legal, Compliance, Communications, and leadership are engaged at appropriate thresholds.
Fraud recall and recovery	Recall is initiated quickly; correspondent / beneficiary institutions are contacted through trusted channels; recovery actions are tracked.
Cyber triage accuracy	Teams distinguish spoofing, lookalike-domain impersonation, and valid-account compromise; evidence supports classification.
Evidence preservation	Email, logs, approvals, call records, payment records, and decision logs are preserved without damaging evidentiary value.
Cross-functional coordination	A clear command structure and action log exist; fraud and cyber workstreams share facts and decisions.
Legal / regulatory awareness	Legal and Compliance assess obligations based on facts, jurisdiction, contractual duties, and recovery status.
Communications	Internal and external messages are accurate, measured, approved, and updated as facts change.
Improvement capture	Lessons learned are specific, owned, prioritized, and tracked to closure.

Scoring scale

Score	Definition
1 - Not demonstrated	No clear owner, action, or evidence; major gaps observed.
2 - Partially demonstrated	Some correct actions, but timing, ownership, or documentation is weak.
3 - Adequate	Core actions are identified, but dependencies or edge cases remain unclear.
4 - Strong	Actions are timely, coordinated, evidence-based, and well documented.
5 - Mature	Actions are rehearsed, measured, integrated across functions, and supported by clear controls and automation.

15. Debrief Questions

- 1 What worked well in the first 30 minutes of the scenario?
- 2 Where did process ambiguity or role confusion emerge?
- 3 Were fraud and cyber workflows integrated or siloed?
- 4 Could the current process withstand a sophisticated executive impersonation attempt that passes basic email authentication for a lookalike domain?
- 5 Are exception paths too easy to invoke under pressure?
- 6 How effective are current out-of-band verification controls, and are they auditable?
- 7 How quickly can the organization initiate a recall and reach correspondent / beneficiary institutions?
- 8 Can Security distinguish spoofing, lookalike-domain abuse, and valid-account compromise quickly enough to support business decisions?
- 9 What immediate procedural or technical changes are needed?
- 10 What long-term control, training, or governance improvements should be prioritized?

16. Recommended Improvement Actions

Timeframe	Actions
Immediate	Reiterate mandatory out-of-band verification for urgent, confidential, high-value, and new-beneficiary transfer requests. Require enhanced review and documented approval for new or changed beneficiaries, especially in cross-border wires. Create a single fraud / cyber rapid-response checklist for payment fraud events, including recall, evidence, and command roles. Tune email controls for executive display-name abuse, lookalike domains, newly observed domains, reply-to mismatch, and suspicious payment language. Confirm that users know how to report suspicious emails while preserving headers and links.
Near term	Test callback procedures, approval authority verification, and executive unavailability contingencies. Review exception handling governance, evidence retention, and auditability for high-value payment approvals. Implement or mature domain monitoring for brand impersonation, certificate transparency, and newly registered lookalike domains. Strengthen identity detection for impossible travel, denied MFA prompts, suspicious OAuth grants, mailbox rules, forwarding, and abnormal sessions. Establish clearer criteria for crisis activation, law-enforcement liaison, insurer notice, external notification, and regulatory assessment.
Longer term	Mature anti-spoofing and anti-impersonation protections, including DMARC enforcement for owned domains and gateway controls for lookalikes. Improve transaction analytics for anomalous urgency, geography, value, beneficiary novelty, and approval-route deviations. Integrate fraud, cyber, treasury, and crisis management playbooks into a single payment-fraud response operating model. Run additional exercises involving confirmed mailbox compromise, valid-account misuse, multi-stage BEC, deepfake callback attempts, or coordinated mule-account activity. Track remediation through governance forums with owners, due dates, risk acceptance, and retesting.

17. Technical Artifact Pack

The following artifact cards can be provided gradually or held by the facilitator to prompt deeper investigation. They are fictional and should not be used in production systems.

Artifact A - Header analysis worksheet

Header / field	Exercise value	Facilitator interpretation
From	"Jane Morris, CFO" <jane.morris@example-bankcorp.example>	Display name impersonates the CFO; domain is lookalike, not the real bank domain.
Reply-To	dealdesk@secure-closing.example	Replies divert to a separate domain controlled by actor.
SPF / DKIM / DMARC	Pass for example-bankcorp.example	Passing authentication for a lookalike domain does not prove legitimacy.
Gateway risk	compauth=fail; impersonation-risk=high; newly-observed-domain=true	Gateway has warning signals that should be reviewed.
Received IP	198.51.100.24	Fictional reserved IP used for exercise tracing.
URL	hxxps://secure-closing.example/doc/cedar	Credential-phishing support artifact.

Artifact B - Message search terms

- Sender domain: example-bankcorp.example
- Reply-to domain: secure-closing.example
- Subject contains: Project Cedar OR settlement instruction OR closing window
- Body contains: confidential acquisition OR legal limiting distribution OR release USD 8,750,000
- URL domain: secure-closing.example
- Source IP: 198.51.100.24
- Recipients in Treasury, Finance, Executive Support, Legal, and Payment Operations

Artifact C - Identity review prompts

- Was there a successful login from 203.0.113.45 or adjacent infrastructure?
- Were MFA challenges approved, denied, or timed out?
- Were sessions created after the click event?
- Were mailbox rules, external forwarding, delegated mailbox access, or OAuth grants created or modified?
- Was the user on a managed device and protected by conditional access?
- Do logs support password reset, session revocation, device isolation, or a broader identity incident?

Artifact D - Payment recovery checklist

- Confirm payment reference, amount, originating account, beneficiary, beneficiary bank, intermediary / correspondent route, and release time.
- Initiate recall / freeze request through trusted fraud or payment-operations channels.
- Escalate to correspondent and beneficiary institution fraud teams; record names, times, methods, and responses.
- Preserve approval trail, exception justification, callback evidence, and operator actions.
- Coordinate with Legal on privilege, law enforcement, insurer notice, and reporting obligations.
- Provide leadership updates with recovery status, exposure, next actions, and decision requests.

18. Optional Variant Paths

Variant	Inject	Purpose
A. Mailbox compromise confirmed	Investigators discover an executive assistant's mailbox has a new rule moving CFO-related replies to a hidden folder and forwarding selected messages externally.	Tests valid-account compromise, mailbox persistence, session revocation, legal hold, and broader cyber incident response.
B. Multiple targets	Similar messages were sent to several approvers in finance and treasury, including one user who approved an unrelated smaller payment.	Tests enterprise-wide search, purge, payment queue review, and fraud analytics.
C. Partial recovery only	A portion of funds moved through additional accounts before the recall landed.	Tests loss assessment, law enforcement, insurer coordination, board / regulator briefing, and communications.
D. Media inquiry	A journalist contacts Communications asking whether the bank lost funds to an executive impersonation fraud.	Tests holding statement, fact discipline, executive alignment, and reputational risk management.
E. Deepfake callback attempt	A follow-up phone call appears to come from the CFO and confirms the request, but voice quality and callback routing are suspicious.	Tests authenticated callback procedures and resilience against voice impersonation.
F. Credentials submitted	A treasury analyst admits entering credentials on the fake closing page; identity logs show a successful login from an unfamiliar IP.	Tests account containment, valid-account investigation, mailbox review, and stronger MITRE mapping to credential access and discovery.

19. Closing

This exercise helps participants rehearse a realistic, high-pressure fraud scenario at the intersection of cybersecurity, operational risk, treasury controls, legal response, and executive decision-making. The quality of the response depends less on malware complexity than on disciplined verification, rapid escalation, coordinated recovery action, evidence-based technical scoping, and a willingness to challenge urgency when normal controls are being bypassed.

The most important learning outcome is a shared operating model: Treasury, Fraud, Security, Legal, Compliance, Communications, and Executive leadership should know how to form a coordinated response, preserve evidence, act quickly under uncertainty, and implement sustainable control improvements.

20. MITRE ATT&CK Mapping

This mapping reflects the exercise scenario and optional variants. Some BEC behaviors are business-process abuse rather than classic endpoint intrusion. The mapping therefore identifies whether each technique is confirmed in the base scenario, attempted / supporting, or optional variant. The final mapping should be adjusted by the facilitator if optional variants are activated.

Tactic	Technique / sub-technique	Status	How reflected in scenario	Evidence / inject
Reconnaissance (TA0043)	T1593 - Search Open Websites/Domains	Inferred	Actor researches public executive profiles, corporate activity, and deal-related context to craft a believable lure.	Threat context
Reconnaissance (TA0043)	T1591 - Gather Victim Org Information	Inferred	Actor understands treasury roles, approval language, payment cadence, and executive hierarchy.	Threat context
Reconnaissance (TA0043)	T1589.002 / T1589.003 - Gather Victim Identity Information: Email Addresses / Employee Names	Inferred	Actor targets CFO, treasury manager, analyst, and executive support recipients.	Threat context / Phase 3

Tactic	Technique / sub-technique	Status	How reflected in scenario	Evidence / inject
Resource Development (TA0042)	T1583.001 - Acquire Infrastructure: Domains	Confirmed	Actor registers a lookalike sender domain to support impersonation.	Phase 1 / Phase 3
Resource Development (TA0042)	T1583.006 - Acquire Infrastructure: Web Services	Confirmed	Actor hosts a fake closing package / credential prompt on external web infrastructure.	Phase 1 / Phase 3
Resource Development (TA0042)	T1585.002 - Establish Accounts: Email Accounts	Inferred	Actor sends mail through actor-controlled or newly established email infrastructure.	Phase 1 headers
Reconnaissance / Initial Access	T1598.003 - Phishing for Information: Spearphishing Link	Attempted	The closing-package link attempts to elicit credentials or session material.	Phase 1 / Phase 3
Initial Access (TA0001)	T1566 - Phishing	Confirmed	Targeted email uses social engineering and trusted executive identity to drive action.	Phase 1
Initial Access (TA0001)	T1566.002 - Spearphishing Link	Attempted	The email contains a link to a fake closing package / login page.	Phase 1 / Phase 2
Initial Access / Defense Evasion	T1078 - Valid Accounts	Optional variant	If credentials are captured and used, actor may access cloud email or identity resources using a legitimate account.	Variant F
Defense Evasion (TA0005)	T1036 - Masquerading	Confirmed	Display name and lookalike domain are manipulated to appear legitimate to users and controls.	Phase 1
Defense Evasion (TA0005)	T1564.008 - Hide Artifacts: Email Hiding Rules	Optional variant	Mailbox rules may hide replies or warnings if an executive-support mailbox is compromised.	Variant A
Discovery (TA0007)	T1087.003 - Account Discovery: Email Account	Optional variant	If valid-account access succeeds, actor may enumerate mail accounts or directory data for additional targeting.	Variant F
Credential Access / Collection	T1056.003 - Input Capture: Web Portal Capture	Attempted	Fake login portal prompts user for credentials after link click.	Phase 2 / Phase 3
Collection (TA0009)	T1114 - Email Collection	Optional variant	If mailbox compromise occurs, actor may collect emails for deal context, approval language, or response monitoring.	Variant A / F
Collection (TA0009)	T1114.003 - Email Forwarding Rule	Optional variant	Forwarding or hidden-rule behavior supports monitoring and persistence in mailbox compromise branch.	Variant A
Command and Control (TA0011)	T1102 - Web Service	Not established / possible	No malware C2 is confirmed. If the phishing kit relays captured data through a web service, this may become relevant.	Variant F
Exfiltration (TA0010)	T1567.004 - Exfiltration Over Webhook	Optional variant	If credentials submitted to the fake portal are relayed to an actor-controlled webhook, this applies to the phishing-kit path.	Variant F
Impact (TA0040)	T1657 - Financial Theft	Confirmed objective	The objective is unauthorized transfer of funds through BEC and fraud.	Phase 2 / Phase 4
Social Engineering	T1684.001 - Social Engineering: Impersonation	Confirmed	Actor impersonates a trusted executive to compel urgent payment action.	All phases
Initial Access	T1199 - Trusted Relationship	Contextual / limited	The scenario abuses internal trust in executive-to-treasury communications; use cautiously because no third-party network access is established in the base case.	Threat context

Mapping caveats for facilitators

- Do not over-map. In the base scenario, there is no confirmed malware, endpoint compromise, or successful internal mailbox compromise.
- Techniques marked optional should be used only if the facilitator activates the relevant variant.
- Financial Theft and Social Engineering / Impersonation capture the business impact and human-manipulation elements that are central to BEC.
- The most important training value is the connection between technical evidence and business decisions: whether to halt payments, recall funds, activate crisis governance, and notify external parties.

Reference framework

Technique IDs and names were aligned to the MITRE ATT&CK Enterprise framework current at the time this exercise was generated. Facilitators should re-check mappings before formal publication if organizational standards require a specific ATT&CK version.